LUXE & THREAD · DOCUMENTATION

INTERNAL – for developers

Internal 14 · Security & Compliance

Audience	INTERNAL – developers, tech lead
Version	2.0 · October 2026

1 · Threats and protections

Threat	Protection	Where
Customer edits prices / stock	server prices everything from PostgreSQL; stock reserved in the order transaction; `CHECK (stock >= 0)`	`lib/pricing.ts`, `repos/catalog.ts`
Two buyers, last piece	conditional `UPDATE … WHERE stock >= n` inside a transaction	`reserveStock`
Fake "payment success"	HMAC-SHA256 of `order_id	payment_id` with key secret
Fake webhooks	Razorpay: signature of raw body · Shiprocket: secret token	`api/webhooks/*`
Timing attacks	`timingSafeEqual`	`lib/crypto.ts`
Password theft	scrypt (N=16384, salted); constant-time check (also for unknown e-mails)	`lib/password.ts`, `admin/actions.ts`
Brute force	8 attempts / 15 min / IP on login; 5 cancels / min; 10 checkouts / min	`rate-limit.ts`
Cookie forgery / privilege escalation	HMAC over `userId.role.expiry`; HttpOnly, Secure (prod), SameSite=Lax, path `/admin`, 8 h; user **re-loaded from DB on every request** (disabled accounts lose access at once)	`admin-session.ts`, `admin-auth.ts`
Admin action without login	every page, server action and CSV route calls `requireAdmin` / `getAdmin`	all admin files
Staff overreach	`owner` role required for refunds, coupons, expenses, reports, customers, audit	`requireAdmin('owner')`
SQL injection	parameterised queries only (`$1…`); LIKE input escaped	`repos/*`
XSS	React escapes output; JSON-LD `<` escaped; e-mail HTML escaped	
CSV injection	cells starting `= + - @` prefixed `'`	`lib/csv.ts`
Malicious upload	size ≤ 3 MB, magic-byte type check, generated file names, served with `nosniff`, safe-name check	`lib/media.ts`, `/media`

Threat	Protection	Where
Reading another's order	secret token in link; wrong token = 404	`order/[id]`, `api/orders/cancel`
Clickjacking / sniffing	`X-Frame-Options: DENY`, `X-Content-Type-Options`, `Referrer-Policy`, `Permissions-Policy`, HSTS	`next.config.ts`
Script injection	**CSP in report-only** (enforce after a clean week)	`next.config.ts`
Secret leaks	env only; logger redacts `secret/password/token/signature/authorization/card`; 5xx messages generic	`logger.ts`, `http.ts`
Card data	never touches our server (Razorpay window) → minimal PCI scope (SAQ A)	–

2 · Secrets handling

Env files `chmod 600`, never in Git; Key **ID** public, **Secret/Webhook secret** server-only; rotate on staff change or suspected leak (MOP §11); different secrets per environment; 2FA on GitHub, Razorpay, Shiprocket, cloud, domain, mailbox; password manager for sharing.

3 · Server hardening checklist

#	Item	Command / note
1	SSH keys only, no root login	`PasswordAuthentication no`, `PermitRootLogin no`
2	Firewall	`ufw allow OpenSSH; ufw allow 'Nginx Full'; ufw enable` (PostgreSQL **not** exposed)
3	PostgreSQL listens on localhost; strong password	`listen_addresses='localhost'`
4	Auto security updates	`unattended-upgrades`
5	fail2ban for SSH	`apt install fail2ban`
6	Nginx: hide version, gzip, rate limit `/admin` & `/api` if desired	`server_tokens off;`
7	Run app as non-root user	PM2 under `ubuntu`
8	Backups encrypted, off-server	Internal 10
9	CDN/WAF (Cloudflare free)	DDoS + bot protection
10	Monitoring + alerts	UptimeRobot on `/api/health`; Sentry for errors

4 · CSP enforcement procedure

1. Browse every page + a full test payment with Chrome DevTools → Console; note `Content-Security-Policy-Report-Only` violations.
2. Add missing hosts to the policy in `next.config.ts` (Razorpay needs `checkout.razorpay.com`, `api.razorpay.com`, `lumberjack.razorpay.com`).
3. After a week without violations rename the header to `Content-Security-Policy`.

5 · Compliance (India) – owner + CA/lawyer to confirm

Topic	Requirement	Status in product
DPDP Act 2023	lawful purpose, consent, correction/deletion, breach plan	consent flags, unsubscribe, order-link privacy; policy text template; deletion by procedure (MOP)
TRAI / DLT	SMS sender + template registration; promotional consent	SMS off by default; guide in Internal 12
GST	correct rate/HSN; tax invoice with numbering; place-of-supply split (CGST/SGST/IGST)	rates/HSN per product (placeholders); **invoice PDF not built yet**
Consumer Protection (E-Commerce) Rules 2020	display seller details, grievance officer, return/refund policy, price incl. taxes	policy pages + footer; add **grievance officer** name/contact to Contact page
Payment gateway rules	Razorpay requires policy pages, contact, T&C	present as templates
Legal Metrology	MRP, net quantity, manufacturer details on products	`mrp` shown; add details in description

6 · Security testing & monitoring

See Internal 11 §6. Review **Admin → Activity log** weekly; alert on repeated `admin login failed` in logs; monthly `npm audit`.

7 · Incident response (security)

Suspected leak → rotate affected secrets immediately → check `audit_log` and logs for unusual admin actions/downloads → disable staff accounts if needed → tell the owner → for personal-data breaches follow DPDP notification duties with legal advice.